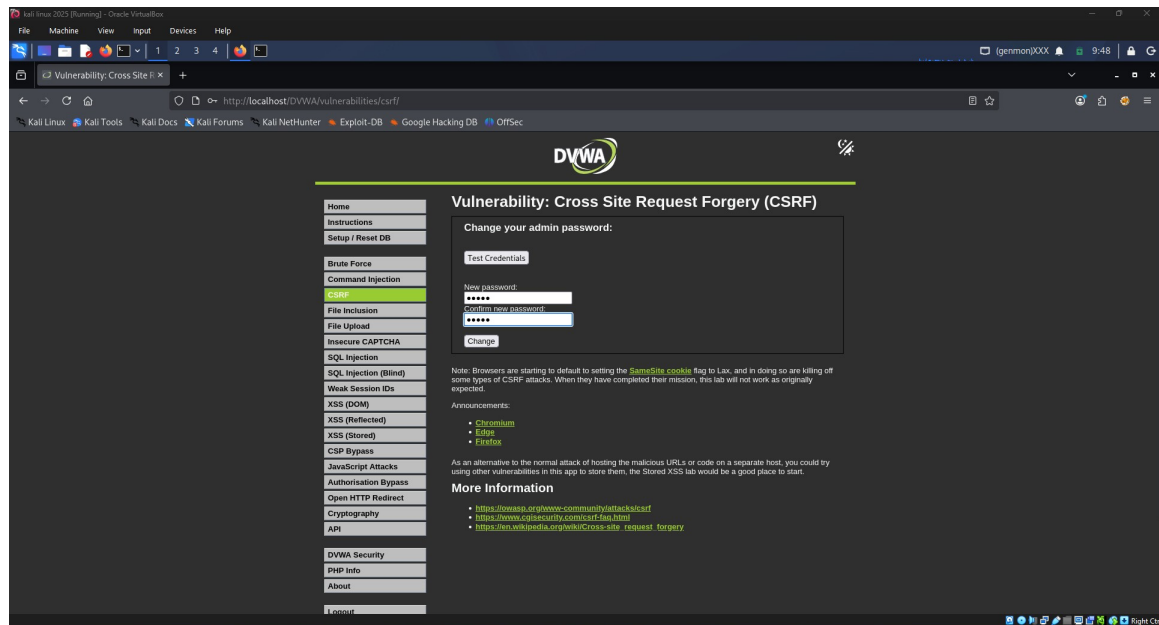


CSRF Attack and Token-Based Protection in DVWA

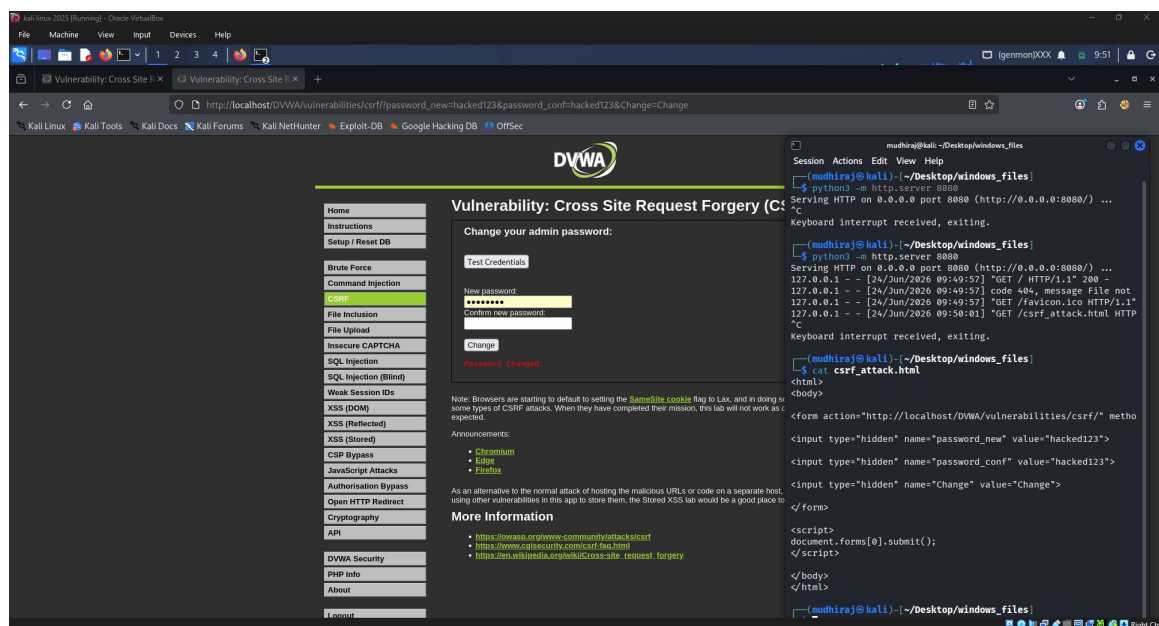
1. Objective

To demonstrate a Cross-Site Request Forgery (CSRF) attack in DVWA and understand how token-based protection mitigates the vulnerability.

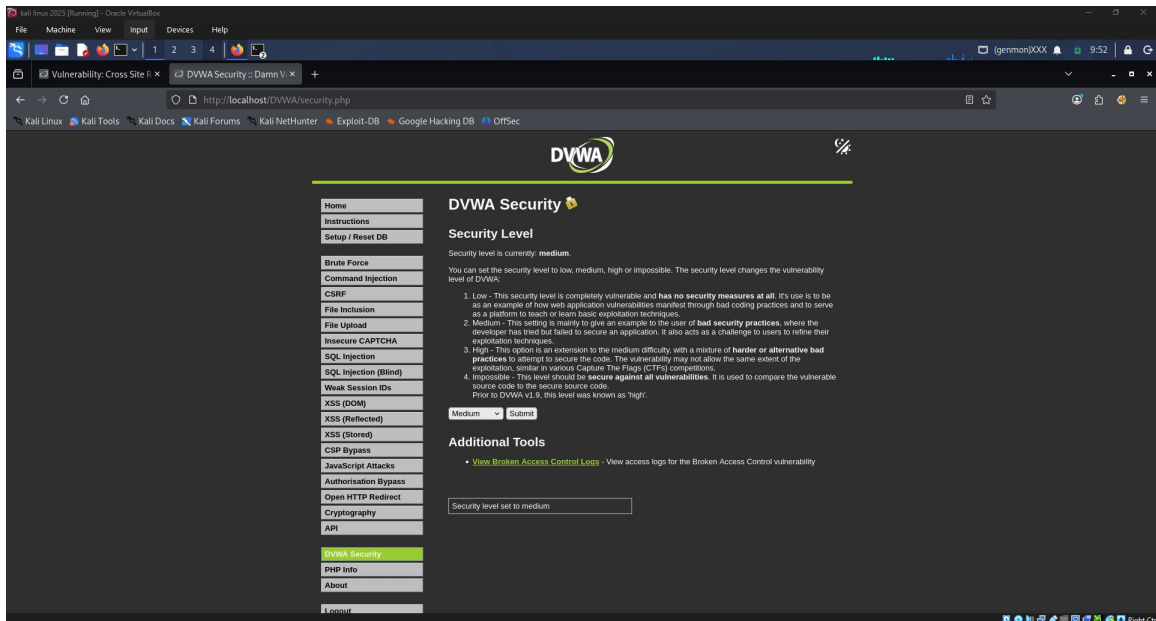
2. Screenshot Details:



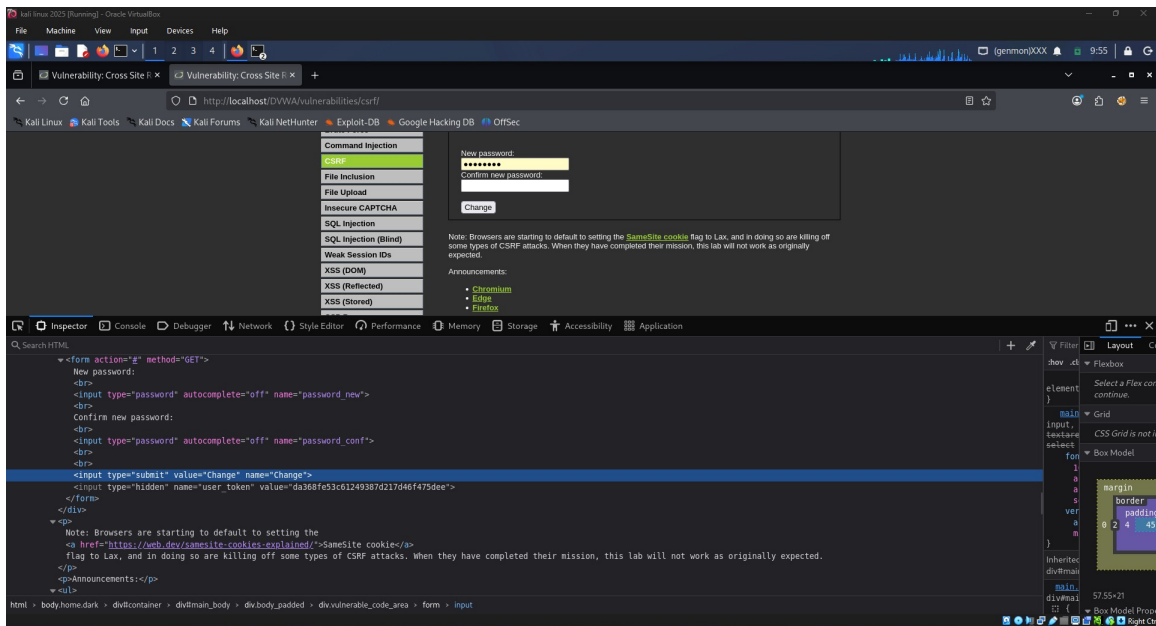
This screenshot shows the DVWA CSRF module where an authenticated user can change the administrator password.



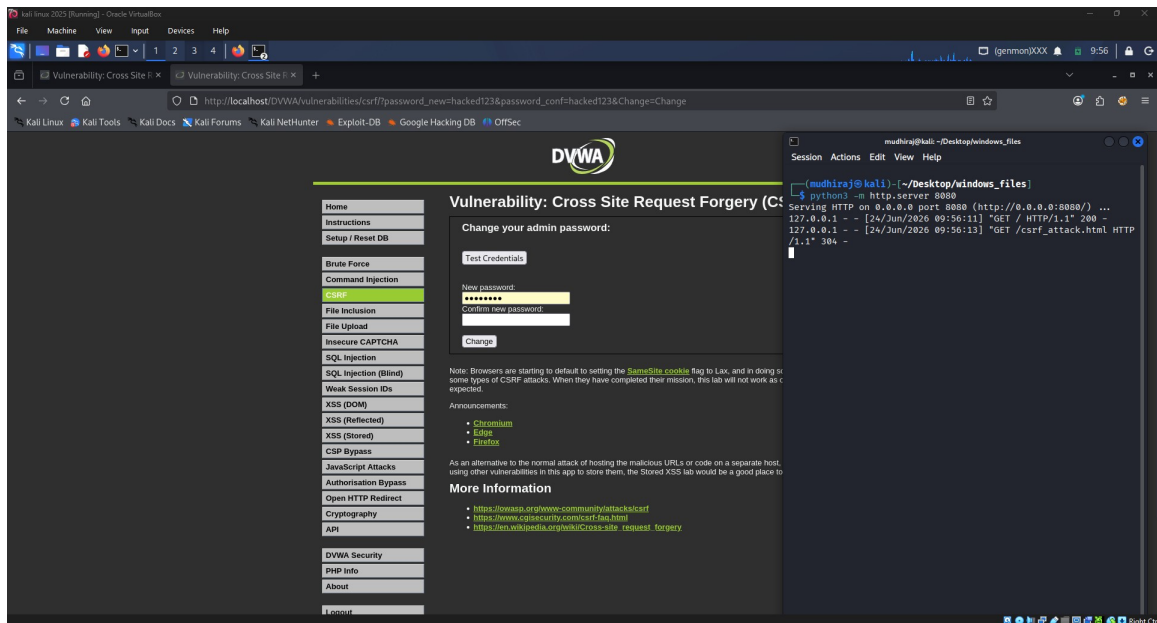
This screenshot demonstrates a successful CSRF attack using a malicious HTML page containing hidden form fields and automatic form submission.



This screenshot shows DVWA security level changed to Medium, enabling additional protection mechanisms.



This screenshot displays the hidden user_token field generated by DVWA for CSRF protection.



This screenshot demonstrates that the forged request is no longer valid when token-based protection is enabled.

3. CSRF Attack Explanation:

CSRF is a web attack that forces an authenticated user to perform unwanted actions. In DVWA Low Security, an attacker can create a malicious HTML page that automatically submits a password change request. Since the victim is already authenticated, the server accepts the request and changes the password.

4. Token-Based Protection:

DVWA Medium Security introduces a hidden `user_token` field. The server validates this token before processing sensitive requests. If the token is missing or invalid, the request is rejected, preventing CSRF attacks.

5. Result:

The CSRF attack was successfully demonstrated in Low Security mode. After enabling Medium Security and using CSRF tokens, the attack was mitigated because forged requests could not provide a valid token.